

Internet infrastructure, how many other ‘cluster-bombs’ are out there?

That cannot be determined until the risk materialises. However, you can take action to ensure that your organisation is prepared for such an event.

How can an SBOM help you?

Modern software solutions are generally made up of layers: the application code, open source and third-party libraries, the open source framework, databases and the underlying cloud infrastructure (see Figure 2).

The presence of security vulnerabilities in any one of these layers may put your solution, intellectual property, employee and customer data at risk of exploitation by hackers. The security features built into your hosted platform may get you one step closer to a secure solution.

However, if security management processes are not implemented across the remainder of your solution stack, your organisation and customers may still be at risk. So how can you protect the remaining layers?

The key question to dealing with vulnerabilities like Log4Shell is, on the day it went public, would your CTO walk into work and know whether Log4j is in your code?

The fundamental aspect to quickly remediating risk in a Log4j type situation is to know exactly what is in your software. The best practice for

this is the consistent production of a software bill of materials (SBOM).

An SBOM is a formal record of components and their associated licences in a piece of software. It is analogous to a list of ingredients on food packaging. An SBOM identifies and lists software components and their licences, and the security vulnerabilities associated with those components (Figure 3).

If your organisation was consistently producing SBOMs, on the day Log4Shell was published, a reference could have quickly been made to the latest SBOM. This would have expressly told you whether Log4j is in your software and whether it is the compromised version.

A software composition analysis (SCA) tool will perform an automated source code scan to produce an SBOM. This will expressly identify all the third-party components within your software and tell you whether any security vulnerabilities are associated with them. An advanced tool will tell you whether your code calls the affected library and suggest a fix.

The National Telecommunications and Information Administration (NTIA), an agency of the United States Department of Commerce, advocates software component transparency. This agency was the main driver behind the SBOM concept back in 2019 as well as the White House Executive Order issued on May 12, 2021, on

improving the nation’s cyber security.

The order states that when dealing with the various departments of the US government, buyers of software solutions must request an SBOM for each product and software solution providers should also supply an SBOM.

In a press conference in early January this year, Jen Easterly, director of the US Federal Cybersecurity and Infrastructure Security Agency, said that CISA is accelerating its efforts to create SBOMs.

Identifying the security vulnerabilities is the first step, but to reduce security risks remediations must be made quickly. Updates and patches for vulnerable software components must be implemented as soon as they are made available.

It is critical for organisations to take immediate actions to identify systems with the Apache Log4j vulnerability, implement mitigation measures, and continually monitor and remediate them. The Apache Foundation has released four patches since the first Log4Shell vulnerability was published, as previous patches left part of the vulnerability unfixed.

Continuous management is the next step to securing your solution stack. A source code scan and SBOM represent one moment in time -- the moment the scan was performed. Due to the nature of modern software development, the reality is that software composition

Name	Component	License	Vulnerabilities
openssh 2.5.1 (BSD or OpenSSH License)	openssh - 2.5.1	None Selected	74 2 7 11 0 54
libpng 1.0.6 (Libpng)	libpng - 1.0.6	libpng License	44 1 3 0 0 40
libjpeg 6b (IJG)	libjpeg - 6b	Independent JPEG Group License	3 0 0 0 0 3
Apache Commons Beanutils 1.7.0 (Apache 2.0)	apache-commons-beanutils - 1.7	Apache License 2.0	2 0 1 0 0 1
commons-beanutils 1.7.0 (Apache 2.0)	commons-beanutils - 1.7.0	Apache License 2.0	2 0 1 0 0 1
modler-zlib 1.2.1 (Zlib)	modler-zlib - 1.2.1	zlib License	2 0 0 0 0 2
modler-zlib 1.2.2 (Zlib)	modler-zlib - 1.2.2	zlib License	2 0 0 0 0 2
zlib 1.2.1 (Zlib)	zlib - 1.2.1	zlib License	2 0 0 0 0 2

Figure 3: A sample of software bill of materials (SBOM)